

# Inteligência Artificial na Governança de Dados: Classificação Automatizada e Mitigação de Riscos em Ambientes Financeiros

*Artificial Intelligence in Data Governance: Automated Classification and Risk Mitigation in Financial Environments*

Gabriela Nogueira Freire, Jade Alves Prado, Matheus Avolio Sedel, Otavio Joaquim  
Fernandes

Centro Universitário Senac — Campus Santo Amaro, São Paulo, SP, Brasil

gabiinog@gmail.com | jade.jadeprado@gmail.com | avoliomatheus.sed@gmail.com |  
taviojf123@gmail.com

## Resumo

A crescente adoção da Inteligência Artificial (IA) no ambiente corporativo, combinada com as exigências regulatórias da Lei Geral de Proteção de Dados Pessoais (LGPD), impõe ao setor financeiro a necessidade de mecanismos robustos de controle sobre o tratamento de dados sensíveis. Este artigo tem como objetivo propor um modelo conceitual de classificação automatizada de dados com IA para apoiar mecanismos de Governança de Dados e mitigação de riscos em ambientes corporativos financeiros. A pesquisa é de natureza exploratória com abordagem qualitativa, desenvolvida por meio de revisão bibliográfica e análise documental da LGPD (Brasil, 2018) e da ABNT NBR ISO/IEC 27001:2022. Os resultados demonstram a viabilidade técnica do uso de modelos de Processamento de Linguagem Natural (PLN), como o Legal-BERT, para classificação automatizada de dados em quatro níveis — Público, Privado, Confidencial e Sensível —, com precisão superior a 90% (Battu, 2025). O modelo conceitual TO-BE proposto integra quatro camadas interdependentes — Governança, Classificação, Controle DLP e Conformidade — e operacionaliza os controles A.5.12 e A.5.13 da ISO/IEC 27001 em conformidade com os arts. 46, 48 e 52 da LGPD. O diagnóstico do processo manual atual (AS-IS) revela fragilidades estruturais que o modelo endereça ao reduzir a dependência do julgamento humano e gerar trilha de auditoria contínua. O estudo contribui para o debate acadêmico sobre automação de compliance e governança de dados, articulando-se ao ODS 9 da Agenda 2030 da ONU.

**Palavras-chave:** inteligência artificial; governança de dados; classificação da informação; proteção de dados; LGPD.

## Abstract

The growing adoption of Artificial Intelligence (AI) in corporate environments, combined with the regulatory requirements of Brazil's General Data Protection Law (LGPD), imposes on the financial sector the need for robust control mechanisms over sensitive data processing. This article aims to propose a conceptual model for automated data classification using AI to support Data Governance mechanisms and risk mitigation in corporate financial environments. The research adopts an exploratory approach with qualitative methodology, developed through bibliographic review and documentary analysis of the LGPD (Brasil, 2018) and ABNT NBR ISO/IEC 27001:2022. Results demonstrate the technical feasibility of Natural Language Processing (NLP) models, such as Legal-BERT, for automated data classification into four levels — Public, Private, Confidential, and Sensitive — with accuracy

exceeding 90% (Battu, 2025). The proposed TO-BE conceptual model integrates four interdependent layers — Governance, Classification, DLP Control, and Compliance — operationalizing ISO/IEC 27001 controls A.5.12 and A.5.13 in accordance with LGPD arts. 46, 48, and 52. The AS-IS process diagnosis reveals structural weaknesses addressed by the model through reduced reliance on human judgment and continuous audit trail generation. The study contributes to academic debate on compliance automation and data governance, aligning with UN Sustainable Development Goal 9 of the 2030 Agenda.

**Keywords:** artificial intelligence; data governance; information classification; data protection; LGPD.

## 1 INTRODUÇÃO

Nos últimos anos, o avanço da transformação digital fez com que as organizações passassem a lidar com volumes cada vez maiores de informações, muitas delas de caráter pessoal ou estratégico. Esse movimento foi acompanhado por um crescimento expressivo no uso de ferramentas de Inteligência Artificial (IA): segundo Cardoso (2025), 55% das organizações já utilizavam IA em ao menos uma função de negócio em 2023, percentual que era de apenas 20% em 2017. Ao mesmo tempo, a entrada em vigor da Lei Geral de Proteção de Dados Pessoais (LGPD), instituída pelo Brasil em 2018 (Brasil, 2018), impôs novas obrigações às empresas quanto ao uso e à proteção dessas informações, com previsão de sanções que podem chegar a R\$ 50 milhões por infração, conforme o art. 52 da lei.

Ainda assim, boa parte dos processos de classificação e compartilhamento de dados ainda é feita por pessoas, o que abre espaço para erros. Dois casos ilustram bem esse problema: o grande vazamento de dados ocorrido no Brasil em fevereiro de 2021 e o escândalo da Cambridge Analytica, em que informações de usuários foram usadas de forma não autorizada para fins políticos. Gaydutschenko (2022) aponta que o custo médio de um único registro de dados pessoais exposto pode chegar a USD 180. Além disso, Cardoso (2025) aponta que ferramentas populares de IA Generativa apresentam lacunas importantes em suas políticas de privacidade, o que pode expor informações corporativas sensíveis de forma inadvertida.

Por outro lado, a própria IA pode ser usada como aliada na proteção dessas informações. Pesquisas recentes mostram que modelos de Processamento de Linguagem Natural (PLN), como o Legal-BERT, atingiram 93,1% de precisão na classificação de documentos regulatórios e contribuíram para reduzir em até 40% a carga de trabalho manual de conformidade (Battu, 2025). Quando aplicada à prevenção de vazamentos de dados (Data Loss Prevention, ou DLP), essa tecnologia é capaz de identificar e classificar informações em tempo real, com base nos quatro níveis definidos pela ABNT NBR ISO/IEC 27001:2022: Público, Privado, Confidencial e Sensível. Os controles A.5.12 e A.5.13 dessa norma estabelecem que as informações devem ser classificadas conforme as necessidades de segurança da organização e devidamente rotuladas (ABNT, 2022). Com o uso da IA, esse processo pode ser feito de forma contínua e automática, reduzindo erros e garantindo maior consistência.

Diante desse cenário, este artigo busca responder à seguinte questão central: como a Inteligência Artificial pode ser utilizada como mecanismo de controle na Governança de Dados para classificar automaticamente informações em trânsito e reduzir riscos de vazamento em ambientes corporativos financeiros, em conformidade com a LGPD e com os requisitos da ISO/IEC 27001? Para respondê-la, este artigo tem como objetivo geral propor um modelo conceitual de classificação automatizada de dados com Inteligência Artificial para apoiar mecanismos de governança e mitigação de riscos em ambientes corporativos financeiros. Para isso, foram definidos os seguintes objetivos específicos: (a) apresentar os fundamentos da Governança de Dados no setor financeiro; (b) analisar os requisitos da LGPD e da ISO/IEC 27001 relacionados à classificação da informação; (c) descrever técnicas de Inteligência Artificial aplicadas à classificação automática de dados; (d) estruturar um modelo conceitual de classificação automática integrado a mecanismos de governança de dados; e (e) discutir as contribuições do modelo para a mitigação de riscos e prevenção de vazamentos de dados. O estudo justifica-se pela relevância acadêmica do tema no contexto regulatório pós-LGPD, pelo impacto social na proteção de dados de titulares e pela aplicação prática para gestores de TI e encarregados de dados (DPO). Ademais, o tema articula-se ao Objetivo de Desenvolvimento Sustentável 9 (ODS 9) da Agenda 2030 da ONU, que preconiza a construção de infraestruturas resilientes, a promoção da industrialização inclusiva e sustentável e o fomento à inovação. O artigo está organizado em Método de Pesquisa, Referencial Teórico, Resultados e Discussão, e Considerações Finais.

## **2 MÉTODO DE PESQUISA**

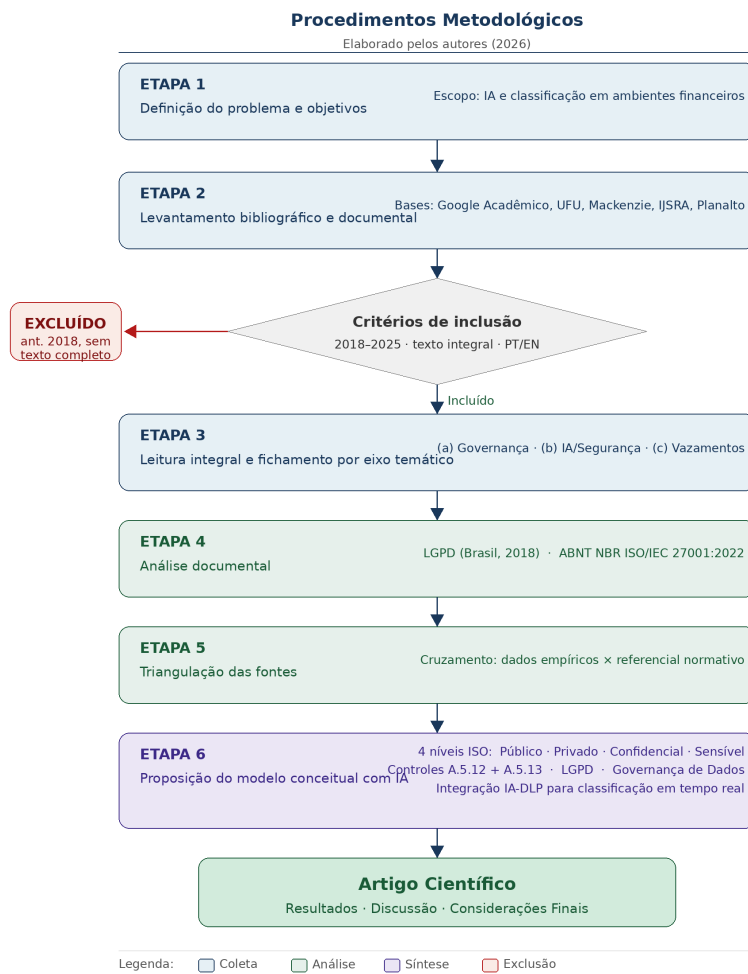
Este trabalho é uma pesquisa exploratória com abordagem qualitativa. Os procedimentos adotados foram a revisão bibliográfica e a pesquisa documental, escolhidos por serem adequados à natureza do objetivo proposto: construir um modelo conceitual a partir da integração de evidências da literatura com os requisitos normativos da LGPD e da ISO/IEC 27001. Essa abordagem segue a mesma linha metodológica adotada por Cardoso (2025), que utilizou análise documental e revisão de literatura para investigar riscos relacionados ao uso de IA em empresas. Neste estudo, a revisão bibliográfica e a análise documental não são fins em si mesmas, mas etapas que fundamentam a estruturação do modelo de classificação automatizada de dados com IA proposto como produto principal da pesquisa.

Os procedimentos metodológicos foram organizados em seis etapas, cada uma com contribuição direta para a construção do modelo conceitual. Na primeira etapa, foram

definidos o problema e os objetivos do estudo, estabelecendo como escopo central a proposta de um modelo de classificação automatizada de dados com IA para ambientes corporativos financeiros. Na segunda etapa, foram realizadas buscas em bases acadêmicas e documentais, incluindo o Google Acadêmico, o Repositório da UFU, o DSpace da Universidade Mackenzie, o periódico IJSRA e o Portal de Legislação do Governo Federal. As palavras-chave utilizadas foram: IA e segurança da informação; Governança de Dados e LGPD; DLP e classificação automatizada; NLP, compliance e regulação financeira; e vazamento de dados e responsabilização. Na terceira etapa, os materiais selecionados foram lidos na íntegra e organizados por eixo temático: (a) governança de dados e conformidade regulatória, (b) IA aplicada à classificação e segurança da informação, e (c) riscos de vazamento e responsabilização.

Para a seleção dos materiais, foram adotados critérios de inclusão: obras publicadas entre 2018 e 2025, disponíveis na íntegra, em português ou inglês, vinculadas a repositórios ou periódicos reconhecidos e alinhadas a pelo menos um dos três eixos temáticos. Foram excluídos trabalhos anteriores a 2018, sem autoria identificada, que tratassem de IA sem relação com dados ou privacidade, ou cujo texto integral não estivesse disponível. Na quarta etapa, foi realizada a análise documental da LGPD e da ABNT NBR ISO/IEC 27001:2022, com foco específico nos dispositivos legais e controles normativos que sustentam a classificação da informação, especialmente os controles A.5.12 e A.5.13. Na quinta etapa, os dados levantados foram triangulados, confrontando os achados da literatura com os requisitos da LGPD e da ISO/IEC 27001. Por fim, na sexta etapa, foi estruturado o modelo conceitual de classificação automatizada com IA, integrando os quatro níveis da ISO/IEC 27001:2022 (ABNT, 2022) às diretrizes de Governança de Dados e às obrigações da LGPD. O percurso metodológico encontra-se sintetizado na Figura 1.

**Figura 1 - Fluxograma dos procedimentos metodológicos**



Fonte: Autores.

### 3 REFERENCIAL TEÓRICO

#### 3.1 Governança de Dados no Setor Financeiro

A Governança de Dados pode ser compreendida como o conjunto de práticas, políticas, processos e estruturas organizacionais que visam assegurar que os dados corporativos sejam gerenciados de forma eficiente, segura e conforme os objetivos do negócio (Cardoso, 2025). No ambiente corporativo, essa disciplina envolve a definição clara de papéis e responsabilidades, entre os quais se destacam o Data Owner, responsável por tomar decisões estratégicas sobre os dados; o Data Steward, encarregado de garantir a qualidade e a conformidade da gestão; e o Data Custodian, que cuida da manutenção física e técnica das informações (Cardoso, 2025). Mais do que um conjunto de boas práticas, a governança atua

como um sistema de diretrizes e tomadas de decisão que organiza, padroniza e orienta o ciclo de vida dos dados dentro da organização.

No setor financeiro, a relevância da Governança de Dados é amplificada por dois fatores: a natureza altamente sensível das informações tratadas — que incluem dados bancários, histórico de transações, perfis de crédito e informações pessoais de clientes — e a intensidade do escrutínio regulatório ao qual essas organizações estão submetidas. A LGPD (Brasil, 2018), em seu art. 6º, estabelece os princípios que devem nortear todo o tratamento de dados pessoais, entre eles a finalidade, a adequação, a necessidade, a segurança e a responsabilização. Quando aplicados ao setor financeiro, esses princípios demandam que as organizações não apenas coletem e processem dados de forma lícita, mas que demonstrem, de forma documentada e auditável, o cumprimento dessas obrigações.

A ausência de governança adequada gera consequências concretas. Cardoso (2025) aponta que o uso de ferramentas de IA sem mecanismos de controle pode comprometer a confidencialidade de informações estratégicas, especialmente quando colaboradores utilizam plataformas externas sem consciência dos riscos. Gaydutschenko (2022) documenta que os próprios agentes de tratamento — controladores, operadores e encarregados — representam um vetor de risco quando não dispõem de políticas claras de classificação e de mecanismos automatizados de controle. Sob a perspectiva da LGPD, o art. 42 determina que controladores e operadores que causarem danos ao titular dos dados em razão do exercício de atividade de tratamento são obrigados a repará-los (Brasil, 2018), o que torna a governança não apenas uma boa prática, mas uma obrigação com consequências jurídicas diretas.

### **3.2 LGPD e ISO/IEC 27001 na Classificação da Informação**

A classificação da informação é o mecanismo central que permite às organizações aplicar controles proporcionais ao nível de sensibilidade de cada dado. No Brasil, a LGPD (Brasil, 2018) fornece o marco jurídico para essa proporcionalidade: o art. 46 determina que os agentes de tratamento devem adotar medidas técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados, enquanto o art. 5º, II define como dados sensíveis aqueles relacionados à origem racial ou étnica, convicção religiosa, opinião política, filiação sindical, saúde, vida sexual, genética ou biometria. A esse marco legal, a ABNT NBR ISO/IEC 27001:2022 acrescenta o instrumental normativo técnico necessário para sua operacionalização. O controle A.5.12 da norma estabelece que as informações devem ser classificadas de acordo com as necessidades de segurança da informação da organização, com

base na confidencialidade, integridade, disponibilidade e requisitos das partes interessadas relevantes (ABNT, 2022).

Complementarmente, o controle A.5.13 estabelece que um conjunto adequado de procedimentos para rotulagem de informações deve ser desenvolvido e implementado de acordo com o esquema de classificação de informações adotado pela organização (ABNT, 2022).

Esses dois controles, em conjunto, fundamentam o modelo de quatro níveis de classificação amplamente adotado por organizações que implementam a ISO/IEC 27001: Público, Privado, Confidencial e Sensível. O nível Público compreende informações que podem ser divulgadas sem restrições, como comunicados institucionais e relatórios publicados. O nível Privado abarca dados de uso interno, acessíveis apenas a colaboradores autorizados. O nível Confidencial envolve informações estratégicas cujo acesso é restrito a grupos específicos e cuja divulgação não autorizada pode causar danos à organização. O nível Sensível, por sua vez, refere-se a dados pessoais sensíveis conforme definidos pela LGPD ou a informações cuja exposição representa risco direto a pessoas ou à organização.

A convergência entre a LGPD e a ISO/IEC 27001 no tratamento da classificação da informação não é casual: ambas partem do mesmo pressuposto de que a proteção de dados exige proporcionalidade. Quanto maior o potencial de dano associado à exposição de uma informação, maiores devem ser os controles aplicados ao seu tratamento. Gaydutschenko (2022) demonstra empiricamente esse princípio ao analisar as consequências jurídicas e humanas de vazamentos de dados pessoais: violações que envolvem dados como endereço residencial, informações financeiras ou dados de saúde geram danos de magnitude substancialmente maior do que a exposição de informações públicas.

Sob a ótica da responsabilização, a LGPD é precisa: o art. 42 determina que o controlador ou o operador que, em razão do exercício de atividade de tratamento de dados pessoais, causar dano patrimonial, moral, individual ou coletivo ao titular dos dados, são obrigados a repará-lo (Brasil, 2018). Gaydutschenko (2022) detalha as distinções entre controlador — que determina as decisões sobre o tratamento — e operador — que realiza o tratamento em nome do controlador —, esclarecendo que ambos podem ser responsabilizados solidariamente em casos de violação, o que reforça a necessidade de controles robustos em toda a cadeia de tratamento de dados.



A classificação automatizada de dados por IA insere-se precisamente nessa lacuna: ao aplicar os quatro níveis da ISO/IEC 27001 de forma contínua e em tempo real, ela permite que as organizações cumpram os requisitos normativos da LGPD e da norma técnica sem depender de processos manuais sujeitos a inconsistências. Esse mecanismo transforma a classificação de uma etapa pontual para um processo dinâmico, capaz de reclassificar informações à medida que seu contexto ou finalidade se alteram.

### **3.3 Inteligência Artificial Aplicada à Classificação Automatizada de Dados**

A Inteligência Artificial pode ser compreendida como um conjunto de técnicas computacionais que busca simular capacidades cognitivas humanas — como o aprendizado, o raciocínio e a tomada de decisões — por meio de algoritmos e modelos matemáticos. Segundo Cardoso (2025), a IA pode ser abordada a partir de quatro estratégias metodológicas principais: sistemas que simulam o pensamento humano de forma abrangente; sistemas que realizam tarefas que requerem inteligência humana; sistemas que reproduzem percepção, raciocínio e ações humanas; e o estudo de agentes inteligentes orientados ao desempenho racional.

No campo específico da classificação de dados e da conformidade regulatória, o Processamento de Linguagem Natural (PLN) emerge como a principal tecnologia habilitadora. Battu (2025) demonstra que modelos de PLN baseados na arquitetura Transformer — como o Legal-BERT e o FinBERT — são capazes de analisar documentos regulatórios complexos, extrair obrigações normativas e classificar informações com alto grau de precisão. Em experimentos conduzidos com regulações da União Europeia, o modelo Legal-BERT com reconhecimento de entidades nomeadas (NER) atingiu precisão de 93,1%, recall de 91,7% e F1-Score de 92,4% (Battu, 2025). Esses resultados posicionam o PLN como uma tecnologia viável para a classificação automatizada de dados em escala corporativa.

Souza e Souza (2024) destacam que a IA se sobressai especialmente em funções que exigem processamento repetitivo e análise de grandes volumes de dados — características que a tornam particularmente adequada para a tarefa de classificação em trânsito. Segundo os autores, a IA é uma tecnologia capaz de interpretar dados e solucionar problemas de forma autônoma. No contexto da segurança da informação, essa capacidade analítica se traduz na habilidade de identificar padrões em fluxos de dados, reconhecer a presença de informações sensíveis — como dados biométricos, financeiros ou de saúde — e acionar os controles de proteção correspondentes antes que a informação seja compartilhada de forma inadequada.

A aplicação da IA à prevenção de vazamentos de dados (Data Loss Prevention, DLP) representa uma evolução significativa em relação às abordagens tradicionais, que dependem de regras fixas e revisão humana. Sistemas DLP baseados em IA são capazes de analisar o conteúdo de documentos, e-mails, mensagens e arquivos em trânsito, identificando automaticamente o nível de classificação correspondente — Público, Privado, Confidencial ou Sensível — com base nos critérios da ABNT NBR ISO/IEC 27001:2022 (ABNT, 2022). Quando uma informação classificada como Confidencial ou Sensível é detectada em um canal de transmissão não autorizado, o sistema pode bloqueá-la, alertar o responsável pelo dado ou acionar fluxos de aprovação, tudo em tempo real.

Battu (2025) documenta que implementações-piloto de sistemas baseados em PLN em instituições financeiras dos Estados Unidos, da União Europeia e da Índia resultaram em redução de aproximadamente 40% na carga de trabalho manual de conformidade e em melhora significativa na velocidade de detecção de riscos regulatórios. Esses dados empíricos sustentam a viabilidade técnica da integração entre IA e sistemas de governança de dados, sugerindo que a automação não apenas reduz o esforço operacional, mas também aumenta a consistência e a precisão dos controles aplicados.

Do ponto de vista jurídico, o art. 20 da LGPD (Brasil, 2018) garante ao titular de dados o direito de solicitar revisão de decisões tomadas unicamente com base em tratamento automatizado de dados pessoais que afetem seus interesses. Souza e Souza (2024) analisam esse dispositivo e apontam que ele impõe ao controlador a obrigação de fornecer informações claras sobre os critérios e procedimentos utilizados pelos sistemas automatizados. Isso significa que sistemas de classificação baseados em IA devem ser não apenas precisos, mas também explicáveis — capazes de justificar, de forma compreensível, por que determinada informação foi classificada em um determinado nível. Essa exigência de explicabilidade (Explainable AI, XAI) é apontada por Battu (2025) como um dos principais desafios técnicos para a implementação responsável de sistemas de classificação automatizada.

### **3.4 Riscos de Vazamento de Dados e Mecanismos de Mitigação**

Os riscos associados ao vazamento de dados pessoais em ambientes corporativos não são meramente hipotéticos: são documentados, quantificáveis e crescentes. Gaydutschenko (2022) descreve o funcionamento do mercado ilícito de dados expostos: após a extração de uma base de dados, as informações são organizadas em plataformas de acesso clandestino — os chamados bots — que permitem, mediante pagamento, o cruzamento de dados pessoais

para identificação e localização de indivíduos. O custo médio por registro exposto pode chegar a USD 180, valor que reflete tanto o preço praticado nesses mercados quanto o custo estimado para as organizações afetadas por incidentes de segurança.

Gaydutschenko (2022) aponta que os vazamentos de dados podem gerar danos de natureza patrimonial, física e moral aos titulares. Os danos patrimoniais incluem fraudes financeiras, estelionato digital e clonagem de identidade, viabilizados pelo acesso a dados bancários e documentos pessoais. Os danos físicos decorrem da exposição de informações como endereço residencial, rotina e dados de localização, que podem ser explorados por criminosos. Os danos morais, por sua vez, resultam da exposição de informações íntimas — como dados de saúde, orientação sexual ou situações pessoais delicadas — cujos efeitos sobre a reputação e a dignidade do titular podem ser irreversíveis.

No contexto corporativo, o caso Cambridge Analytica ilustra como o uso indevido de dados pessoais em sistemas automatizados de perfilamento pode transcender a esfera individual e impactar processos democráticos. Gaydutschenko (2022) descreve que, naquele caso, informações de usuários de redes sociais foram submetidas a um processo detalhado de perfilamento político, no qual características como idade, endereço, posicionamento ideológico e opção sexual foram cruzadas para segmentar e influenciar o comportamento eleitoral de grupos específicos. A ausência de controles sobre o compartilhamento e a finalidade do uso dos dados foi o vetor central que tornou possível esse desvio.

Cardoso (2025) mapeia, a partir da análise de documentos de organismos internacionais como a ENISA, a OECD e o NIST, cinco categorias de risco que se potencializam no uso de ferramentas de IA: a coleta e retenção indevida de dados inseridos nos sistemas; a falta de transparência sobre o uso e o destino dessas informações; o compartilhamento com terceiros sem consentimento explícito; a ausência de mecanismos de controle e exclusão; e a conformidade legal limitada de ferramentas que operam globalmente sem adequação às legislações locais de proteção de dados. No contexto brasileiro, essa última categoria é particularmente relevante, pois a LGPD impõe requisitos específicos que nem sempre são atendidos por plataformas de IA desenvolvidas fora do país.

Diante desses riscos, a LGPD (Brasil, 2018) estabelece, no art. 46, que os agentes de tratamento devem adotar medidas técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão. Esse mandato legal é a base jurídica que fundamenta a

implementação de sistemas DLP com IA: ao classificar automaticamente as informações em trânsito e aplicar controles diferenciados por nível de sensibilidade, a tecnologia atende diretamente à exigência normativa de proteção proporcional ao risco.

A mitigação efetiva dos riscos de vazamento exige, portanto, a combinação de três elementos: um marco regulatório claro — fornecido pela LGPD e pela ISO/IEC 27001 —, uma taxonomia de classificação operacional — os quatro níveis Público, Privado, Confidencial e Sensível — e uma tecnologia capaz de aplicar essa taxonomia de forma contínua e automatizada. Quando esses três elementos são integrados, a organização passa a dispor de um mecanismo de controle que opera em tempo real, reduz a dependência de processos manuais sujeitos a falhas humanas e produz registros auditáveis de todas as operações de classificação realizadas, fortalecendo tanto a conformidade regulatória quanto a capacidade de resposta a incidentes.

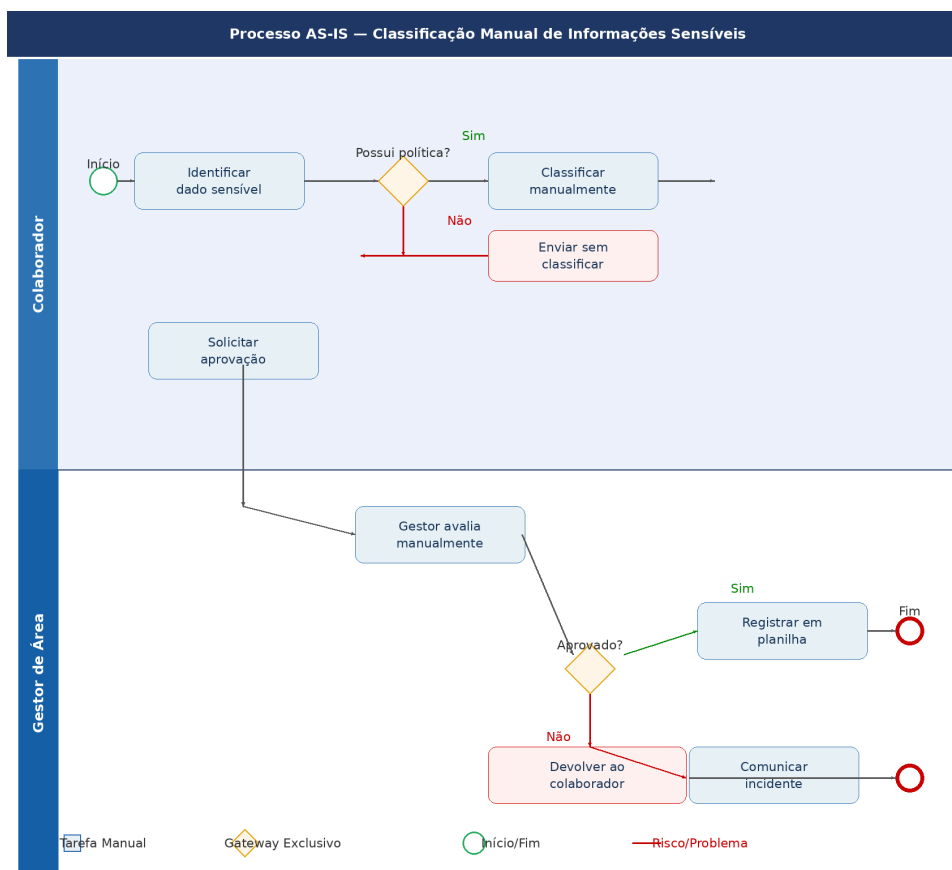
## **4 RESULTADOS E DISCUSSÃO**

Esta seção apresenta os resultados obtidos por meio da revisão bibliográfica e da análise documental descritas na Seção 2, organizados em cinco eixos analíticos: o diagnóstico do processo atual de classificação manual (AS-IS); o desempenho de modelos de PLN em tarefas de classificação regulatória; as lacunas de governança identificadas em ferramentas de IA Generativa; a estruturação do modelo conceitual TO-BE; e as contribuições e limitações do modelo proposto. A articulação entre esses eixos permite responder à questão central do artigo e demonstrar a viabilidade técnica e normativa da integração entre IA, LGPD e ISO/IEC 27001 no contexto corporativo financeiro.

### **4.1 Diagnóstico do Processo Atual: AS-IS da Classificação Manual**

Antes de propor o modelo com IA, é necessário compreender como o processo de classificação de informações sensíveis ocorre atualmente nas organizações. O Diagrama AS-IS (Figura 2), elaborado em notação BPMN, representa o fluxo manual vigente em dois atores principais: o Colaborador, responsável por identificar e encaminhar o dado, e o Gestor de Área, responsável por avaliar e aprovar o compartilhamento.

**Figura 2 - Diagrama AS-IS: processo atual de classificação manual de informações sensíveis**



Fonte: Autores.

O diagrama evidencia as principais fragilidades do processo manual: a ausência de critério padronizado de classificação, a dependência de julgamento individual do colaborador para identificar a sensibilidade do dado e a possibilidade de envio sem classificação quando não há política clara disponível. Gaydutschenko (2022) documenta que esse tipo de falha operacional está na origem de grande parte dos incidentes de vazamento de dados, pois os próprios agentes de tratamento representam um vetor de risco quando não dispõem de mecanismos automatizados de controle. Além disso, o processo atual não gera trilha de auditoria sistemática, dificultando a demonstração de conformidade exigida pelo art. 46 da LGPD (Brasil, 2018).

#### 4.2 Desempenho de Modelos de PLN na Classificação de Documentos Regulatórios

A viabilidade técnica do uso de IA para classificação automatizada pode ser verificada a partir dos resultados apresentados por Battu (2025). O estudo avaliou cinco arquiteturas de PLN aplicadas a corpora regulatórios de diferentes jurisdições, utilizando quatro métricas: precisão, recall, F1-score e acurácia de conformidade, sintetizadas no Quadro 1.

**Quadro 1 - Desempenho de modelos de PLN na classificação de documentos regulatórios financeiros**

| Modelo          | Dataset                   | Precisão (%) | Recall (%) | F1-Score (%) | Conformidade (%) |
|-----------------|---------------------------|--------------|------------|--------------|------------------|
| Legal-BERT+NER  | EU Directives Corpus      | 93,1         | 91,7       | 92,4         | 90,8             |
| Legal-BERT      | U.S. SEC Regulations      | 91,2         | 88,7       | 89,9         | 87,5             |
| FinBERT         | RBI Circulars (Índia)     | 88,5         | 86,3       | 87,4         | 85,2             |
| Longformer      | Basel III Full Texts      | 86,7         | 83,9       | 85,3         | 82,4             |
| LSTM-SVM (base) | Corpus multijurisdicional | 79,4         | 76,1       | 77,7         | 74,3             |

Fonte: Adaptado de Battu (2025).

O Quadro 1 evidencia hierarquia clara de desempenho. O modelo Legal-BERT+NER aplicado ao corpus de Diretivas da União Europeia obteve os melhores resultados em todas as métricas, com precisão de 93,1% e acurácia de conformidade de 90,8%. Em contraposição, o modelo híbrido LSTM-SVM registrou os menores índices, com precisão de 79,4% — diferença de cerca de 18 pontos percentuais que demonstra que a arquitetura e a especialização do corpus de treinamento são fatores determinantes para a efetividade do sistema. Isso implica que a adoção de IA para classificação de dados no contexto brasileiro demanda modelos treinados com corpus jurídico nacional, incluindo os requisitos da LGPD (Brasil, 2018) e as normas setoriais aplicáveis.

Além dos resultados quantitativos, Battu (2025) relata que os pilotos conduzidos em instituições financeiras nos Estados Unidos, na União Europeia e na Índia resultaram em redução de aproximadamente 40% na carga de trabalho manual de conformidade. No setor financeiro brasileiro, em que equipes de compliance operam sob alta pressão regulatória, essa redução operacional permite que os profissionais concentrem sua atuação em casos que exigem julgamento humano, como situações de ambiguidade regulatória ou decisões sobre dados sensíveis conforme o art. 5º, II da LGPD (Brasil, 2018).

#### 4.3 Lacunas de Governança em Ferramentas de IA Generativa

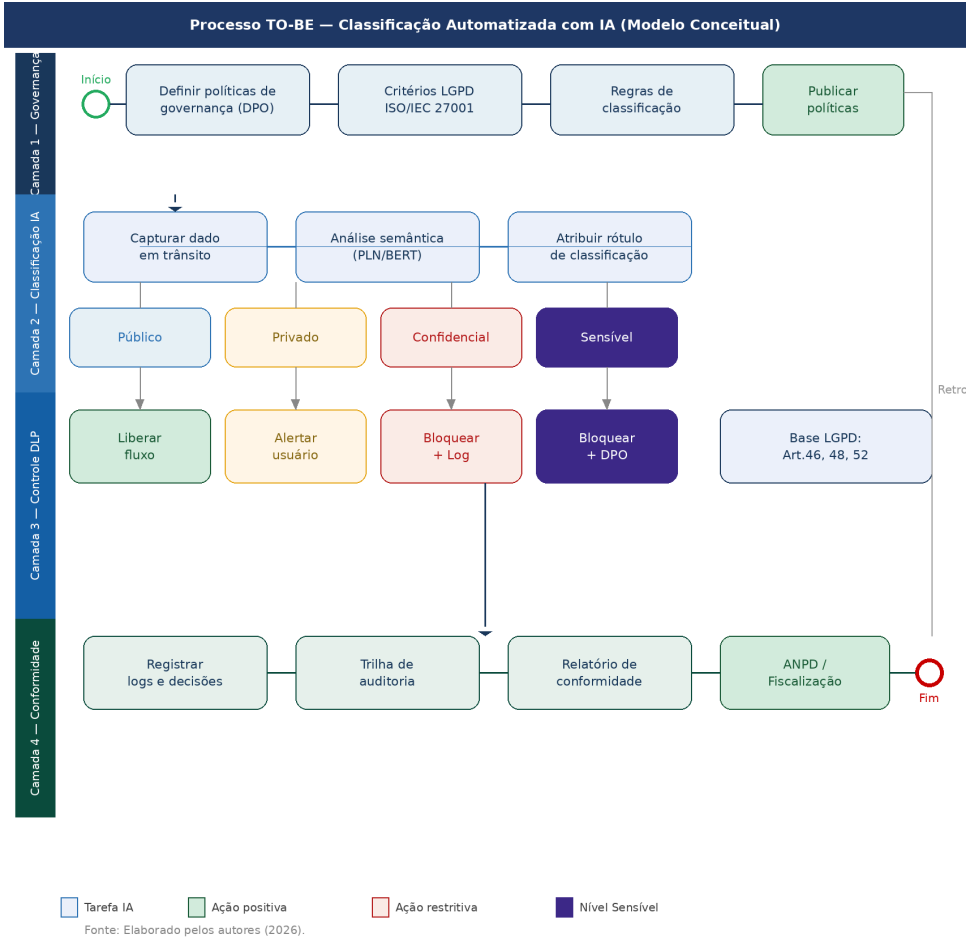
Se os dados de Battu (2025) demonstram o potencial da IA como mecanismo de controle, os achados de Cardoso (2025) revelam o risco oposto: a IA sendo vetor de exposição de dados sensíveis quando utilizada sem governança adequada. O estudo analisou as políticas de privacidade de ChatGPT, Copilot e Gemini e as comparou com diretrizes internacionais e com a LGPD. Os resultados mostraram que nenhuma das ferramentas menciona diretamente a LGPD em seus documentos públicos, e todas admitem o uso de prompts para aprimoramento dos modelos, o que significa que informações corporativas confidenciais digitadas por colaboradores podem ser incorporadas aos processos de treinamento das plataformas.

Cardoso (2025) identifica nessa prática uma lacuna de conformidade com os requisitos de governança, pois fere o princípio da finalidade previsto na LGPD e compromete a confidencialidade das informações no sentido definido pelo controle A.5.12 da ISO/IEC 27001:2022 (ABNT, 2022). Esse cenário reforça a necessidade do modelo proposto: se as próprias ferramentas de IA Generativa representam canal de vazamento involuntário, um mecanismo de classificação automatizada que identifique e rotule as informações antes de qualquer interação com plataformas externas torna-se camada essencial de controle, alinhando-se ao art. 46 da LGPD (Brasil, 2018).

#### **4.4 Modelo Conceitual TO-BE: IA como Mecanismo de Controle na Governança de Dados**

Com base no diagnóstico AS-IS e na revisão da literatura, foi estruturado o modelo conceitual TO-BE de classificação automatizada com IA, representado na Figura 3. O modelo parte do princípio de que a IA não substitui a Governança de Dados, mas atua como mecanismo de controle automatizado, operacionalizando as diretrizes normativas da LGPD e da ISO/IEC 27001 sobre dados em trânsito. O fluxo integrado inicia-se na definição de políticas de governança, avança pela classificação automatizada e pelo controle DLP, e culmina no registro para auditoria e conformidade, conforme ilustrado a seguir.

**Figura 3 - Diagrama TO-BE: modelo conceitual de classificação automatizada com IA**



Fonte: Autores.

O modelo opera em quatro camadas interdependentes, sintetizadas no Quadro 2. A Camada 1 (Governança de Dados) define as políticas, os papéis organizacionais e os critérios normativos que orientam o sistema — sem essa base, a IA não tem critério decisório e apenas automatizaria erros. A Camada 2 (Classificação Automatizada) é onde modelos de PLN como Legal-BERT analisam semanticamente os dados em trânsito — e-mails, uploads, chamadas de API e prompts em ferramentas externas — e atribuem automaticamente um dos quatro rótulos definidos pela ISO/IEC 27001:2022 (ABNT, 2022). A Camada 3 (Mecanismo de Controle DLP) operacionaliza ações diferenciadas conforme o nível classificado. A Camada 4 (Conformidade e Auditoria) garante a rastreabilidade de todas as decisões, produzindo evidências para a ANPD e para auditorias internas.

**Quadro 2 - Modelo conceitual de classificação automatizada integrado à LGPD e à ISO/IEC 27001:2022**

| Nível | Definição (ISO A.5.12) | Exemplos no setor financeiro | Ação da IA (DLP) | Base normativa (LGPD) |
|-------|------------------------|------------------------------|------------------|-----------------------|
|-------|------------------------|------------------------------|------------------|-----------------------|



|                     |                                              |                                                |                                          |                                 |
|---------------------|----------------------------------------------|------------------------------------------------|------------------------------------------|---------------------------------|
| <b>Público</b>      | Informações sem restrição de acesso          | Relatórios anuais, comunicados ao mercado      | Monitoramento passivo; sem bloqueio      | Art. 7º — tratamento permitido  |
| <b>Privado</b>      | Informações de uso interno                   | Políticas internas, procedimentos operacionais | Alerta ao usuário antes do envio externo | Art. 46 — medidas de segurança  |
| <b>Confidencial</b> | Informações sensíveis ao negócio             | Dados de clientes, contratos, estratégias      | Bloqueio + registro de log               | Art. 46 + Art. 48 — incidentes  |
| <b>Sensível</b>     | Dados pessoais sensíveis (art. 5º, II, LGPD) | Dados biométricos, saúde financeira, crédito   | Bloqueio imediato + notificação ao DPO   | Art. 5º, II + Art. 11 + Art. 52 |

Fonte: Autores.

A diferenciação de resposta conforme o nível de classificação é o elemento central do modelo. Dados Sensíveis — definidos pelo art. 5º, II da LGPD (Brasil, 2018) como aqueles relacionados à saúde, biometria, origem racial, opinião política e orientação sexual, entre outros — requerem tratamento imediato e diferenciado. No contexto financeiro, esse conceito se expande para incluir dados de perfil de crédito, histórico de transações e outras informações cuja exposição pode gerar danos patrimoniais aos titulares, conforme documentado por Gaydutschenko (2022). O modelo garante que esses dados recebam o mais alto nível de proteção automatizada, independentemente da ação humana.

#### 4.5 Contribuições do Modelo e Limitações

A análise combinada dos dados levantados permite identificar três contribuições principais do modelo. A primeira é a redução da dependência de ações humanas: sistemas de PLN especializados operam com precisão superior a 88% mesmo nos modelos menos especializados (Battu, 2025), superando significativamente a taxa de erro humano em processos manuais. A segunda é a criação de trilha de auditoria contínua: o modelo prevê o registro de todas as ações de controle, gerando logs para auditorias regulatórias e para responsabilização perante a ANPD, em alinhamento ao art. 48 da LGPD (Brasil, 2018). A terceira é a escalabilidade: a integração com plataformas GRC via APIs RESTful viabiliza operação em tempo real (Battu, 2025), diferencial relevante frente às abordagens manuais.

O modelo apresenta, contudo, limitações que devem ser explicitadas. A primeira diz respeito à possibilidade de falsos positivos e negativos: mesmo modelos com alta precisão classificam incorretamente uma parcela dos dados. A segunda refere-se à explicabilidade: modelos transformadores como Legal-BERT funcionam como caixas-pretas, o que dificulta a validação das decisões por compliance officers — desafio reconhecido por Battu (2025) e diretamente relacionado ao direito do titular previsto no art. 20 da LGPD (Brasil, 2018), que

garante a revisão de decisões automatizadas e foi analisado por Souza e Souza (2024). A terceira é a dependência de dados rotulados de qualidade para treinamento e a necessidade de atualização contínua dos modelos à medida que novas regulações são publicadas. Essas limitações reforçam que a supervisão humana permanece indispensável para a validação das classificações em casos de ambiguidade.

## 5 CONSIDERAÇÕES FINAIS

Este artigo propôs um modelo conceitual de classificação automatizada de dados com Inteligência Artificial para apoiar mecanismos de Governança de Dados e mitigação de riscos em ambientes corporativos financeiros. O desenvolvimento do modelo foi fundamentado na revisão da literatura e na análise documental da LGPD (Brasil, 2018) e da ABNT NBR ISO/IEC 27001:2022, conforme os procedimentos metodológicos descritos.

Os resultados demonstram que modelos de PLN especializados em domínios jurídico-regulatórios são tecnicamente viáveis como núcleo de um sistema de classificação automatizada, com precisão superior a 90% nas melhores configurações avaliadas (Battu, 2025). Quando integrados a uma política de controle baseada nos quatro níveis de classificação da ISO/IEC 27001:2022 — Público, Privado, Confidencial e Sensível — esses modelos podem atuar como mecanismo ativo de prevenção a vazamentos, reduzindo a dependência de intervenção humana e fortalecendo a conformidade com a LGPD. O diagnóstico AS-IS revelou que o processo manual atual apresenta fragilidades estruturais — ausência de padronização, dependência de julgamento individual e ausência de trilha de auditoria — que o modelo TO-BE proposto endereça diretamente. A análise das ferramentas de IA Generativa (Cardoso, 2025) reforçou a urgência desse mecanismo ao demonstrar que as plataformas mais adotadas pelo mercado apresentam lacunas relevantes de conformidade com a legislação brasileira.

Como limitação, este estudo adota abordagem conceitual e não realiza implementação ou validação empírica do modelo em ambiente real. Os dados de desempenho utilizados foram extraídos de pesquisa conduzida em contexto multijurisdicional (Battu, 2025), o que exige cautela na extrapolação direta para o contexto regulatório brasileiro. Estudos futuros devem desenvolver protótipos funcionais e testá-los com corpora de documentos reais do setor financeiro nacional, avaliando a aderência específica às exigências da LGPD e do Banco Central do Brasil. Recomenda-se ainda a investigação de técnicas de IA explicável (XAI) que tornem as classificações auditáveis e compreensíveis para gestores e DPOs, condição

essencial para adoção institucional em escala e conformidade com o art. 20 da LGPD (Brasil, 2018), cuja análise jurídica foi desenvolvida por Souza e Souza (2024).

## REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. *ABNT NBR ISO/IEC 27001: segurança da informação, segurança cibernética e proteção à privacidade — sistemas de gestão da segurança da informação — requisitos*. 3. ed. Rio de Janeiro: ABNT, 2022. Disponível em: [https://www.educacao.pr.gov.br/sites/default/arquivos\\_restritos/files/documento/2025-08/sd\\_iso\\_27001\\_sistema\\_gestao\\_seguranca\\_informacao.pdf](https://www.educacao.pr.gov.br/sites/default/arquivos_restritos/files/documento/2025-08/sd_iso_27001_sistema_gestao_seguranca_informacao.pdf). Acesso em: 13 mar. 2026.

BATTU, Geol Gladson. "Automated Interpretation of Financial Regulations Using NLP: A Compliance-Centric Analysis of Legal Texts and Policy Adherence Frameworks". *International Journal of Science and Research Archive*, v. 15, n. 3, p. 832-840, jun. 2025. DOI: <https://doi.org/10.30574/ijrsra.2025.15.3.1580>. Disponível em: [https://ijrsra.net/sites/default/files/fulltext\\_pdf/IJSRA-2025-1580.pdf](https://ijrsra.net/sites/default/files/fulltext_pdf/IJSRA-2025-1580.pdf). Acesso em: 25 fev. 2026.

BRASIL. *Lei nº 13.709, de 14 de agosto de 2018*. Dispõe sobre a proteção de dados pessoais e altera a Lei nº 12.965, de 23 de abril de 2014. Brasília, DF: Presidência da República, 2018. Disponível em: [https://www.planalto.gov.br/ccivil\\_03/\\_ato2015-2018/2018/lei/113709.htm](https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/113709.htm). Acesso em: 8 mar. 2026.

CARDOSO, Jefferson Dias. *IA Generativa em ambientes corporativos: análise dos riscos de segurança e governança*. 2025. Trabalho de Conclusão de Curso (Bacharelado em Sistemas de Informação) — Universidade Federal de Uberlândia, Monte Carmelo, 2025. Disponível em: <https://repositorio.ufu.br/handle/123456789/45935>. Acesso em: 25 fev. 2026.

GAYDUTSCHENKO, Iwan. *Vazamentos de dados: uma análise a partir da LGPD e das políticas de compliance*. 2022. Trabalho de Conclusão de Curso (Graduação em Direito) — Universidade Presbiteriana Mackenzie, São Paulo, 2022. Disponível em: <https://dspace.mackenzie.br/items/c08c0b22-9def-447c-8b02-eaffb6809dd6>. Acesso em: 25 fev. 2026.

ORGANIZAÇÃO DAS NAÇÕES UNIDAS. *Transformando nosso mundo: a Agenda 2030 para o Desenvolvimento Sustentável*. Nova York: ONU, 2015. Disponível em: <https://brasil.un.org/pt-br/sdgs>. Acesso em: 27 mar. 2026.

SOUZA, Ronnie de Andrade; SOUZA, Janaina Silva de. "Inteligência artificial e a segurança da informação, uma análise com base na Lei Brasileira nº 13.709/2018". *Research, Society and Development*, v. 13, n. 7, e10513746373, 2024. DOI: <http://dx.doi.org/10.33448/rsd-v13i7.46373>. Disponível em: <https://rsdjournal.org/index.php/rsd/article/view/46373>. Acesso em: 25 fev. 2026.